AlfonsoOrozcoAguilarnoNDA Update airgapped.md 160b4f4 · 6 minutes ago

375 lines (281 loc) · 15.9 KB

airgapped

Funciones PHP de apoyo para analizar bases de código legacy en entornos **air-gapped** (aislados, sin acceso a internet).

- **Fecha:** 6 de noviembre de 2026
- **Compatibilidad:** PHP 5.6 a 8.4
- **Licencia:** MIT (al final de este documento)
- **Archivo de código:** `airgapped.php` (todo el código de este documento está también ahí)

Qué es y para qué sirve

En un entorno air-gapped no hay Composer, ni CDNs, no Inteligencia Artificial o LLM, ni StackOverflow, ni forma de descargar una librería si algo falla. Cuando se llega a un sistema legacy desconocido (código PHP viejo, base MySQL sin documentación, sin ayuda externa) hacen falta unas cuantas herramientas pequeñas, autocontenidas y probadas de antemano.

Este kit reúne las funciones de apoyo necesarias para el primer reconocimiento:

Necesidad	Función
Saber qué archivos PHP hay y dónde están	`listaArchivosPHP()`

Necesidad	Función
Radiografía rápida de cada archivo: codificación, BOM, clases, tamaño	`infoArchivoPHP()`
Consultar MySQL sin que un query vacío o fallido rompa la pantalla	`aValues319()`
Truncar importes a los decimales que exige el SAT, sin errores de flotante	`CFDINumbers()` / `CFDINumbers2()`
Generar nombres o identificadores al vuelo	`randomstring()`
Headers sin caché y todo en UTF-8	bloque de inicio

Todas son independientes del resto del sistema, no descargan nada y se comportan igual de PHP 5.6 a 8.4.

Requisitos (verificar en el servidor antes de empezar)

Extensión	Verificación	Se usa en
mbstring	`function_exists('mb_internal_encoding')`	bloque de inicio
bcmath	`function_exists('bcdiv')`	solo `CFDINumbers()`
tokenizer	`function_exists('token_get_all')`	`infoArchivoPHP()` (si falta, usa un respaldo con regex, menos preciso)
mysqli	`function_exists('mysqli_connect')`	`aValues319()`
SPL y PCRE	incluidas por defecto	`listaArchivosPHP()`, `CFDINumbers2()`

Una forma rápida de verlo todo: ejecutar `airgapped.php?test=1` en el navegador o `php airgapped.php test` en consola. El reporte inicial dice qué extensiones tiene el servidor y corre los casos de prueba.

Nota Sobre Moprosoft CMMI normas iso 27001:2022

Moprosoft es la Norma Mexicana NMX-I-059-NYCE. Fue adoptada como norma mexicana en 2005, y se compone de varias partes: la 01 define conceptos y productos, la 02 establece los requisitos de procesos (el modelo MoProSoft propiamente dicho), la 03 es la guía de implantación y la 04 son las directrices de evaluación (EvalProSoft). Hay versiones de 2005, 2011 y 2016. La Parte 2 de 2016 figura como vigente y cancela la de 2011. De MoProSoft salió además la norma internacional ISO/IEC 29110 para entidades muy pequeñas (está basada en la norma mexicana).

La evaluación de Moprosoft también trabaja con niveles de capacidad (la evaluación se basa en ISO/IEC 15504), así que hay qe considerar si tienen CMMI de que nivel o razón técnica por la que usan CMMI.

Lo que sí es cierto, en la práctica:

En el caso de Iso 27001 Su Anexo A reúne controles agrupados en cuatro temas (organizacionales, de personas, físicos y tecnológicos):

- Antivirus y protección contra malware
- Control de accesos, incluyendo cuentas de solo lectura y mínimo privilegio
- Medios removibles (USB) y dispositivos personales
- Gestión de cambios, que se enlaza con lo "bomberazos"
- Respaldos, bitácoras y separación de entornos

ISO27001 Es certificable y de pago. Al igual que con Moprosoft, hablar de “conformidad” requiere una auditoría formal.

Ninguno de los dos es software. Son modelos de prácticas, y se pueden aplicar sin conexión. Moprosoft está pensado para organizaciones pequeñas y medianas, con procesos más ligeros y plantillas de productos de trabajo (manual de mantenimiento, de operación, trazabilidad). Eso lo hace más cómodo para un análisis de un sistema legacy que CMMI, que es más pesado de montar. Por lo mismo usar como estructura de documentación. Escribe “estructura al estilo Moprosoft” o “alineado a” y no “conforme a Moprosoft”. Declarar conformidad requiere una evaluación formal por una entidad acreditada, y probablemente lmno lo tengan ni de ISO 27001.

Cómo llevarlo al entorno aislado y entender la política operativa.

1. **Preferido:** el archivo `airgapped.php` por el medio que autorice el área de sistemas.

Verificar que llegó íntegro comparando su hash (`sha256sum airgapped.php`) contra el del original.

2. **Respaldo:** imprimir este `.md` (o su PDF) y teclear solo lo que haga falta. Por eso el código completo está en este documento.
3. Guardar siempre en **UTF-8 sin BOM**. Un BOM o un espacio antes de `<?php` provoca "headers already sent".
4. Pregunta clave: ¿Hay alguna forma autorizada de pasar un archivo a mi equipo de trabajo (USB aprobado, carpeta compartida, un equipo de transferencia)? Explicar que es para funciones de apoyo necesarias en Legacy.
5. Si te dan un Linux o un Mac de trabajo, pide además acceso a una máquina con la misma imagen que usan los operadores, o a una virtual, para la prueba final. Sin eso, tu veredicto sobre las pantallas de administración tendría un asterisco.
6. Sobre Windows, la actualización y el antivirus son responsabilidad del área de sistemas del cliente, no tuya. Lo que sí te toca es pedirles la misma configuración que tienen los operadores (mismo navegador, mismas políticas), y no tocar nada de actualizaciones ni antivirus aunque tengas permisos. Documentar qué versión encuentras sí es parte de tu análisis.
7. Hay que saber que versión de antivirus es. Documentarlo internamente como Fecha, equipo, hallazgo: sin antivirus (o definiciones desactivadas desde X). Se informó a [persona/área] el [fecha]. Respuesta: [lo que digan, o “pendiente”].

Código

Encabezados y codificación

Deben ir antes de cualquier salida.

```php
<?php
if (!headers_sent()) {
    header("Expires: Tue, 03 Jul 2001 06:00:00 GMT");
    header("Last-Modified: " . gmdate("D, d M Y H:i:s") . " GMT");
    header("Cache-Control: no-store, no-cache, must-revalidate");
    header("Cache-Control: post-check=0, pre-check=0", false);
    header("Pragma: no-cache");
    header('Content-Type: text/html; charset=UTF-8');
}

//  this is a dummy char for pspad, no remove é

ini_set('default_charset', 'UTF-8');

// REQUIERE mbstring. En PHP 8.x alguna puede avisar "Deprecated"; por es
if (function_exists('mb_internal_encoding')) @mb_internal_encoding('UTF-8
if (function_exists('mb_http_output'))       @mb_http_output('UTF-8');

// Desde PHP 8.1 mysqli lanza excepciones por defecto. Se apaga para que
// aValues319() maneje los errores como en PHP 5.6 a 8.0.
if (function_exists('mysqli_report')) mysqli_report(MYSQLI_REPORT_OFF);
```

`aValues319` : consulta MySQL que siempre regresa un arreglo

Requiere **mysqli** y que `$link` ya sea una conexión establecida.

- Sin datos, o query que no es SELECT (insert/update/delete): regresa `array("")` , así que `$a[0]` es `""` y no truena.
- Con datos: arreglo plano (fila 1 col 1, fila 1 col 2, fila 2 col 1, ...). Quien la llama debe conocer el número de columnas.
- Los `NULL` se convierten en `""` .
- Usa `mysqli_fetch_row` (por posición), así que no falla con columnas repetidas en un JOIN.

```
// Respaldo: si el sistema ya define cssalert() se usa la suya.
if (!function_exists('cssalert')) {
    function cssalert($color, $html) {
        return '<div style="color:' . $color . ';font-family:monospace">'
    }
}

function aValues319($Qx) {
    global $link;

    $rsX = mysqli_query($link, $Qx);

    if ($link->error <> '') {
        echo cssalert("red", "<br /><br /><br /><br /><li>" . htmlspecial
        return array("");
    }

    // insert/update/delete devuelven true, no un resultset
    if (!($rsX instanceof mysqli_result)) return array("");

    if (mysqli_num_rows($rsX) == 0) {
        mysqli_free_result($rsX);
        return array("");
    }

    $aDataX = array();
    while ($regX = mysqli_fetch_row($rsX)) {
        foreach ($regX as $v) {
            $aDataX[] = ($v === null) ? "" : $v;
        }
    }
    mysqli_free_result($rsX);
    return $aDataX;
}
```

Ejemplo:

```
$a = aValues319("SELECT nombre, saldo FROM carteras WHERE id = 10");
echo $a[0];   // nombre, o "" si no existe
echo $a[1];   // saldo, o ""
```

listaArchivosPHP : inventario de archivos

Ruta completa de todos los archivos `.php` de forma recursiva, ordenados. Usa solo clases SPL y salta las carpetas sin permiso. Si el sistema usa otras extensiones (`.inc` , `.phtml` , `.php3` ...), ampliar el arreglo `$ext` .

```php
function listaArchivosPHP($ruta) {
    $resultado = array();
    $ext = array('php'); // ej: array('php','inc','phtml','php3','php4','

    $ruta = realpath($ruta);
    if ($ruta === false || !is_dir($ruta)) return $resultado;

    try {
        $it = new RecursiveIteratorIterator(
            new RecursiveDirectoryIterator($ruta, FilesystemIterator::SKI
            RecursiveIteratorIterator::LEAVES_ONLY,
            RecursiveIteratorIterator::CATCH_GET_CHILD
        );
        foreach ($it as $archivo) {
            if ($archivo->isFile() && in_array(strtolower($archivo->getEx
                $resultado[] = $archivo->getPathname();
            }
        }
    } catch (Exception $e) {
        // regresa lo que alcanzó a recolectar
    }

    sort($resultado);
    return $resultado;
}
```

`infoArchivoPHP` : radiografía de un archivo

Regresa un texto como `YNY|1680` :

Posición	Significado
1	`Y` si es UTF-8 válido (un archivo solo ASCII cuenta como `Y`)
2	`Y` si tiene BOM UTF-8 (EF BB BF) al inicio
3	`Y` si declara clases (no cuenta `Foo::class` ni `new class`)
después de `|`	número de líneas

Archivo ilegible: `???|0`. Un `N` en la posición 1 casi siempre indica ISO-8859-1 o Windows-1252, común en sistemas legacy en español. Requiere **tokenizer** (si falta, usa un respaldo con regex).

```php
function infoArchivoPHP($archivo) {
    if (!is_file($archivo) || !is_readable($archivo)) return "???|0";

    $c = file_get_contents($archivo);
    if ($c === false) return "???|0";

    // 1) UTF-8 válido
    $utf8 = ($c === '' || preg_match('//u', $c) === 1) ? 'Y' : 'N';

    // 2) BOM UTF-8
    $bom = (substr($c, 0, 3) === "\xEF\xBB\xBF") ? 'Y' : 'N';

    // 3) Clases declaradas
    $clases = 'N';
    if (function_exists('token_get_all')) {
        $tokens = @token_get_all($c);
        $prev = null;
        foreach ($tokens as $t) {
            if (is_array($t)) {
                $id = $t[0];
                if ($id === T_WHITESPACE || $id === T_COMMENT || $id ===
                if ($id === T_CLASS && $prev !== T_DOUBLE_COLON && $prev
                    $clases = 'Y';
                    break;
                }
                $prev = $id;
            } else {
                $prev = $t;
            }
        }
    } else {
        if (preg_match('/^\s*(?:abstract\s+|final\s+)*class\s+[A-Za-z_]\w
    }

    // 4) Número de líneas
    if ($c === '') {
        $lineas = 0;
    } else {
        $lineas = substr_count($c, "\n");
        if (substr($c, -1) !== "\n") $lineas++;
    }

    return $utf8 . $bom . $clases . '|' . $lineas;
}
```

Primer reconocimiento: las dos juntas

```php
foreach (listaArchivosPHP('/var/www/html') as $f) {
    echo infoArchivoPHP($f) . "  " . $f . "\n";
}
```

Qué buscar en el resultado:

- **Archivos con muchas líneas:** suelen ser el corazón del sistema.
- `N` **en UTF-8:** habrá problemas de acentos; probablemente Latin-1.
- `Y` **en BOM:** causa clásica de "headers already sent" o espacios raros en la salida.
- `N` **en clases:** código procedural; las funciones globales son el mapa.

`CFDINumbers` : truncado con bcmath

Trunca (sin redondear) a 2 decimales. Requiere **bcmath**. Ignora `$p`, y con valores no numéricos o floats puede variar según la versión de PHP (en PHP 8 un valor no numérico lanza `ValueError`).

```php
function CFDINumbers($val, $p = 2) {
    // https://stackoverflow.com/questions/9944001/delete-digits-after-tw
    $res = bcdiv($val, 1, 2);
    if ($val == 0) return "0.00";
    return $res;
}
```

`CFDINumbers2` : truncado sin extensiones

Trunca a `$p` decimales con manipulación de texto. **No requiere bcmath**, respeta `$p`, evita `-0.00` y se comporta igual de PHP 5.6 a 8.4. Conviene pasar el valor como string (los `DECIMAL` de MySQL ya llegan así).

```php
function CFDINumbers2($val, $p = 2) {
    $p = max(0, (int)$p);

    // floats: formato fijo, sin notación científica
    if (is_float($val)) $val = sprintf('%.8F', $val);

    // limpia separadores de miles, signo de pesos y espacios
    $val = str_replace(array(',', '$', ' '), '', trim((string)$val));

    // valida; si no es numérico se trata como 0
    if (!preg_match('/^([+-]?)(\d*)(?:\.(\d*))?$/', $val, $m)
        || ($m[2] === '' && (!isset($m[3]) || $m[3] === ''))) {
        $m = array('', '', '0', '');
    }

    $neg = ($m[1] === '-');
    $ent = ltrim($m[2], '0');
    if ($ent === '') $ent = '0';
    $dec = isset($m[3]) ? $m[3] : '';

    if ($p > 0) {
        $dec = substr(str_pad($dec, $p, '0'), 0, $p);
        $res = $ent . '.' . $dec;
    } else {
        $res = $ent;
    }

    // evita "-0.00"
    if ($neg && trim($res, '0.') !== '') $res = '-' . $res;
    return $res;
}
```

Resultados esperados (verificación rápida en el servidor):

Llamada	Resultado
CFDINumbers2("12.349")	12.34
CFDINumbers2("5")	5.00
CFDINumbers2(".5")	0.50
CFDINumbers2("-0.004")	0.00
CFDINumbers2("1,234.999")	1234.99
CFDINumbers2(0.1+0.2)	0.30

Llamada	Resultado
`CFDINumbers2("12.349", 6)`	`12.349000`
`CFDINumbers2("")`	`0.00`

Ambas funciones solo **truncan**. Si algún campo requiere redondeo, hay que usar otra función.

`randomstring` : cadena alfanumérica

Para nombres de archivo e identificadores casuales. **No usar para tokens ni claves.** `random_int` existe desde PHP 7; en 5.6 usa `mt_rand` .

```
function randomstring($leng = 10) {
    $leng = (int)$leng;
    if ($leng <= 0) $leng = 10;
    $abc = 'ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz012345678
    $max = strlen($abc) - 1;
    $res = '';
    for ($i = 0; $i < $leng; $i++) {
        $res .= $abc[function_exists('random_int') ? random_int(0, $max)
    }
    return $res;
}
```

Siguiente paso sugerido

Escanear el contenido de cada archivo buscando `mysqli_connect` , `mysql_connect` y `new mysqli` para ubicar dónde están las conexiones, y los nombres de tablas después de `FROM` , `JOIN` , `INTO` y `UPDATE` . Con eso se arma un mapa de qué archivo toca qué tabla. Si hay shell:

```
grep -rl "mysqli_connect\|mysql_connect\|new mysqli" /ruta --
include=*.php
```

Licencia

MIT License

Copyright (c) 2026 Alfonso Orozco Aguilar

Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files (the "Software"), to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions:

The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

THE SOFTWARE IS PROVIDED "AS IS", WITHOUT WARRANTY OF ANY KIND, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO THE WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE AND NONINFRINGEMENT. IN NO EVENT SHALL THE AUTHORS OR COPYRIGHT HOLDERS BE LIABLE FOR ANY CLAIM, DAMAGES OR OTHER LIABILITY, WHETHER IN AN ACTION OF CONTRACT, TORT OR OTHERWISE, ARISING FROM, OUT OF OR IN CONNECTION WITH THE SOFTWARE OR THE USE OR OTHER DEALINGS IN THE SOFTWARE.